AI for Product Development

Activity 10: Conduct a Risk and Control Review

C840 • v1.0

Threat-model an agent workflow and assign layered controls, evidence and owners.

1. Purpose and deliverable

Threat-model an agent workflow and assign layered controls, evidence and owners.

Required output: Risk register, permission map and control test plan

Acceptance: High risks have preventive and detective controls, named owners and testable evidence.

2. Folder inventory

brief.yaml — machine-readable scope and decision contract

prompt.md — bounded agent instruction

data/mock-data.csv and mock-context.json — synthetic evidence

solution/expected-output.json — trainer reference shape

scripts/verify_activity.py — deterministic completeness check

evidence/checklist.md — learner sign-off record

3. Detailed procedure

1. Read brief.yaml and restate the product decision, output and acceptance rule.

2. Inspect the CSV and JSON inputs; list source IDs, dates, contradictions and missing evidence.

3. Open prompt.md and select an approved agentic AI builder. Do not add live data or integrations.

4. Ask the agent to plan the workflow before producing the artifact. Check roles, tools, data and stop conditions.

5. Execute the activity-specific workflow: Map assets → Identify threats → Score exposure → Select controls → Assign owner → Test control.

6. Require citations to source IDs and label every inference or assumption.

7. Review the output at the human gate; compare it with the acceptance rule and reject unsupported claims.

8. Save the artifact and evidence inside a learner working copy of this folder.

9. Run python3 scripts/verify_activity.py and retain the JSON result.

10. Complete evidence/checklist.md and record PASS, REPAIR or STOP with a named owner.

4. Troubleshooting

Missing citations: require row-level source IDs and rerun only the unsupported section.

Unstable recommendation: freeze criteria, rerun the same input and perform sensitivity analysis.

Verifier failure: compare the missing file or field with brief.yaml, repair it and rerun.

Unsafe action proposed: stop, remove live/external access and return the decision to the human owner.

5. Verification

Pass condition: High risks have preventive and detective controls, named owners and testable evidence.

The deterministic verifier checks package completeness; the human reviewer checks evidence quality and decision fitness.